

Cybersecurity & Blockchain

KGSP Enrichment [Week 3 & 4 – 2026]





Mudassar Aslam

(FHEA, PhD Cybersecurity)

Associate Professor of Cybersecurity & Program Director,
School of Engineering, Computing and Mathematics,
Oxford Brookes University,
Oxford, United Kingdom.
maslam@brookes.ac.uk

www.mudassir.info



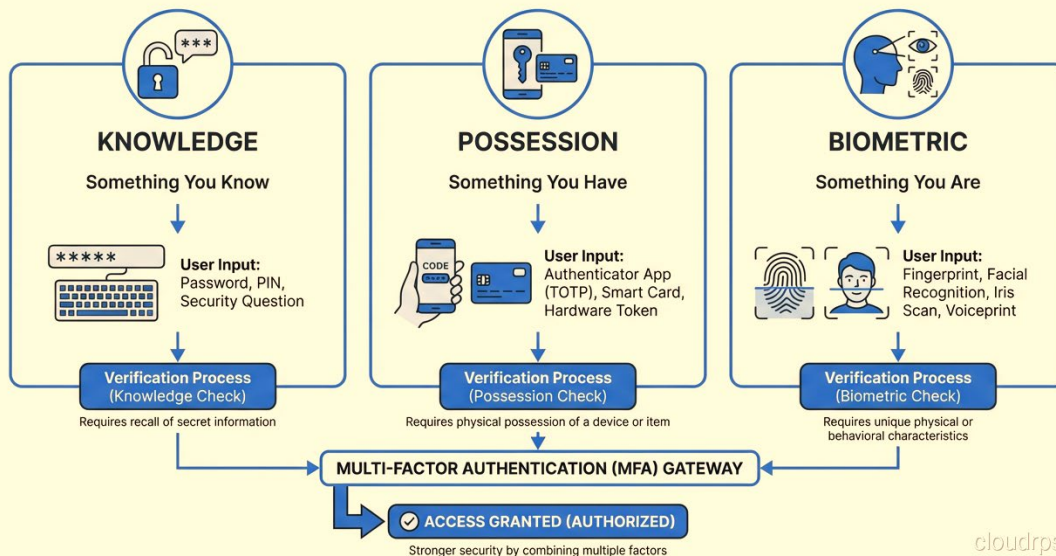
Millions of Cars Hacked (Again)



Day 02 - Securing Access

AUTHENTICATION FACTORS: KNOWLEDGE, POSSESSION, AND BIOMETRIC

Authentication vs Authorization: What's the Difference and Why It Matters



cloudrps.com



جامعة الملك عبد الله
للعلوم والتقنية
King Abdullah University of
Science and Technology

Access Control

- Access Control is about restricting the access to the assets for only authorized subjects

- Physical Assets
- Data + Cyber Physical systems

- Physical Access Control
- Logical Access Control



Protect staff and systems



Prevent intruders and theft



Audit trail and compliance
with regulations

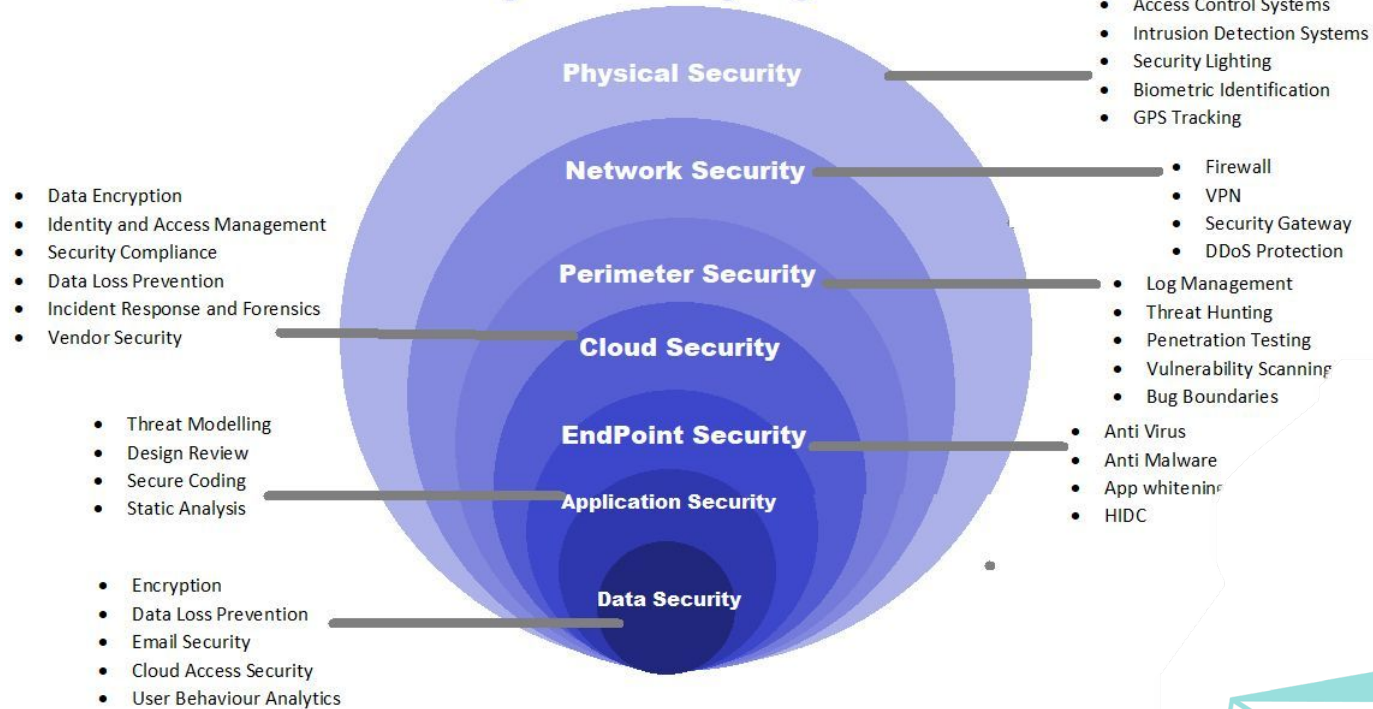


Integration across physical
and logical access

Cybersecurity Layers

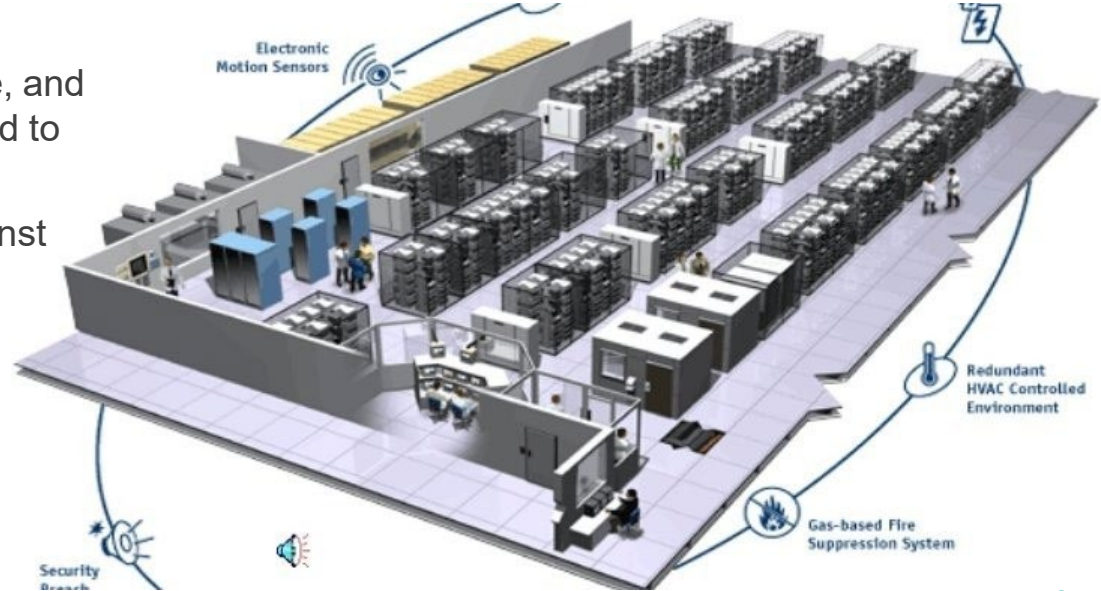


Cyber Security Layers:



Physical Assets

- Data centers
 - contain all of the servers, storage, and other computing resources needed to run our business
 - must have restricted access against potential theft
- Server rooms
- Media storage facilities
- Evidence storage rooms
- Wiring closets



Physical Security Controls

- Fencing, Bollards (retractable) used to block vehicle access
- Natural Surveillance: The idea is that when people can see and be seen, there is a natural deterrent to criminal activity
For example: placing windows appropriately, creating open areas around fences, and using adequate lighting
- Visitor Management
 - Visit reasons, visitor access to facilities (visit reason)
 - maintain a log of that access.
 - identification badges
- Surveillance Cameras
- Physical Security Personnel
 - Human judgement, trained, uniformed, sometimes armed



Logical Assets: Digital Attack Surface

- **Intangible infrastructure of Cybersecurity:** Logical assets are the non-physical, digital components of an information system. Unlike physical servers, these are the informational constructs, codebases, and virtualized environments where modern cyber attacks actually occur.
- **Data:** Intellectual Property (IP), Personally Identifiable Information (PII), cryptographic keys, and user credentials
- **Computers & Networks:** IP addresses, subnets, VLANs, routing tables, and Active Directory domains
- **Software & Dependencies:** Operating Systems (OS), third-party libraries, middleware, and open-source packages
- **Cloud Environments:** AWS S3 buckets, Azure Active Directory, serverless functions, and containerized clusters (Kubernetes).

Access Control Steps

Identification

- An individual makes a claim about their identity

Authentication

- The individual proves their identity to the satisfaction of the access control system

Authorization

- Access control system needs to be satisfied that you are allowed to access the system

Accounting

- Allows administrators to track user activity and reconstruct it from logs

Conventional Access Control Process



Digital Access Control



When we log in to a system, we most often **identify** ourselves using a **username**.



When we reach the **authentication** phase, we're commonly asked to enter a **password**.



Authorization is implemented using **access control lists** that itemize the **resource** permissions granted to an **entity**.



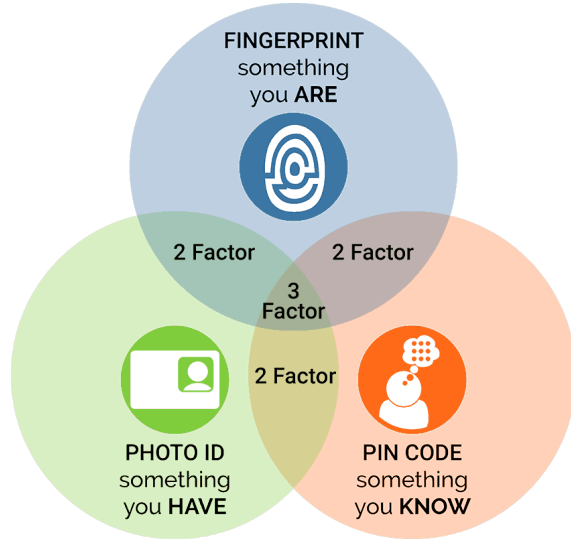
Accounting may include tracking user activity on systems and even **logging** user web browsing history.



Authentication Factors



Multi Factor Authentication (MFA)



Password Security



Length

Complexity

Expiration

History

Resets

Reuse

Password
managers

Password Security Quiz

▪ Length

- How do you rate this password? **P@ssw0rd!1**
- How do you rate this password? **Tr0ub4dur&3**
- How do you rate this password? **correcthorsebatterystaple**

Password Attacks

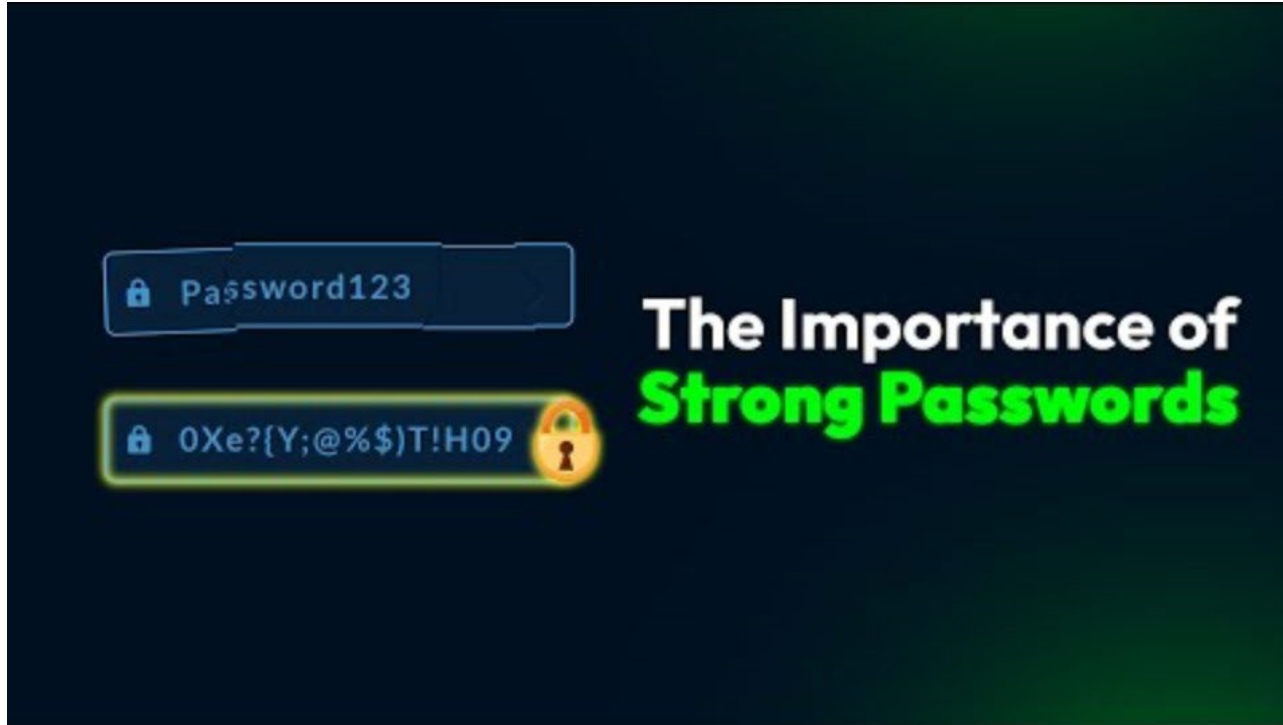
- Online Attacks (Interacting with the website)
 - Submitting guesses into a login page
 - Defense: Easy to stop! Websites just lock the account after 5 wrong attempts or add network rate limits.
- Offline Attacks (The Real Danger)
 - Passwords are **never** stored in clear text
 - The hacker steals the database file from the server which store password **hashes**
 - /etc/shadow (Linux based OS)
 - C:\Windows\System32\config\SAM (Windows OS)
 - Because hash algorithms are fast, a modern hacker machine with GPU can calculate billions of (SHA-256) hashes per second. Your password database can be cracked in minutes. Now, they can guess millions of passwords a second on their own hardware without the website ever knowing.

Rainbow Tables and Password Salting

- Rainbow tables store large sets of pre-computed hashes and reductions to speed up cracking
- A **salt** is a random value unique per password, stored alongside the hash.
- The salt is combined with the password before hashing (e.g. password + salt).
- Salts prevent pre-computed attacks (**rainbow tables**) and ensure identical passwords have different hashes.

Plaintext Password	Hashed Value (MD5)
123456	e10adc3949ba59abbe56e057f20f883e
password	5f4dcc3b5aa765d61d8327deb882cf99
qwerty	d8578edf8458ce06fbc5bb76a58c5ca4
admin	21232f297a57a5a743894a0e4a801fc3
12345678	25d55ad283aa400af464c76d713c07ad
password123	482c811da5d5b4bc6d497ffa98491e38

Password Security



Authorization

- The process of determining whether a **user or system** has **permission** to access a specific **resource** or perform a specific action. It occurs after authentication, which verifies the identity of the user
- Key Terms
 - **Subject**: The entity (user, process, or device) that requests access to a resource
 - **Object**: The resource or data that the subject wants to access
 - **Permission**: The authorization to perform a specific action on an object
 - **Role**: A collection of permissions that can be assigned to subjects
 - **Access Control List**: A list that specifies which subjects have access to certain objects and the types of actions they can perform

Authorization implemented through ACL

Access Control List (ACL) for an object

	Title	Owner Control	Promote Version	Modify Content	Modify Props	View Content	View Props	Publish	Remove
	 Administrator	✓	✓	✓	✓	✓	✓	✓	☐
	 carol		✓	✓	✓	✓	✓		☐
	 Finance Admins	✓	✓	✓	✓	✓	✓	✓	☐
	 Finance Clerks				✓	✓	✓		☐
	 Finance Managers	✓	✓	✓	✓	✓	✓	✓	☐
	 Finance Reviewers					✓	✓		☐

Access Control Entry
(ACE)

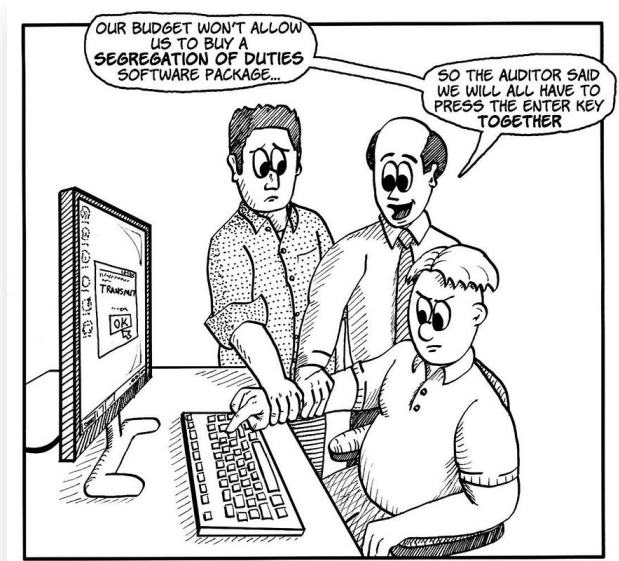
Access levels

Principle of Least Privilege

- An individual should only have the minimum set of permissions necessary to accomplish their job duties
- Important for the following reasons:
 - Minimizes the potential damage from an insider attack, mistakes
 - Limits the ability of an external attacker to quickly gain privileged access when compromising an employee's account

Segregation of Duties

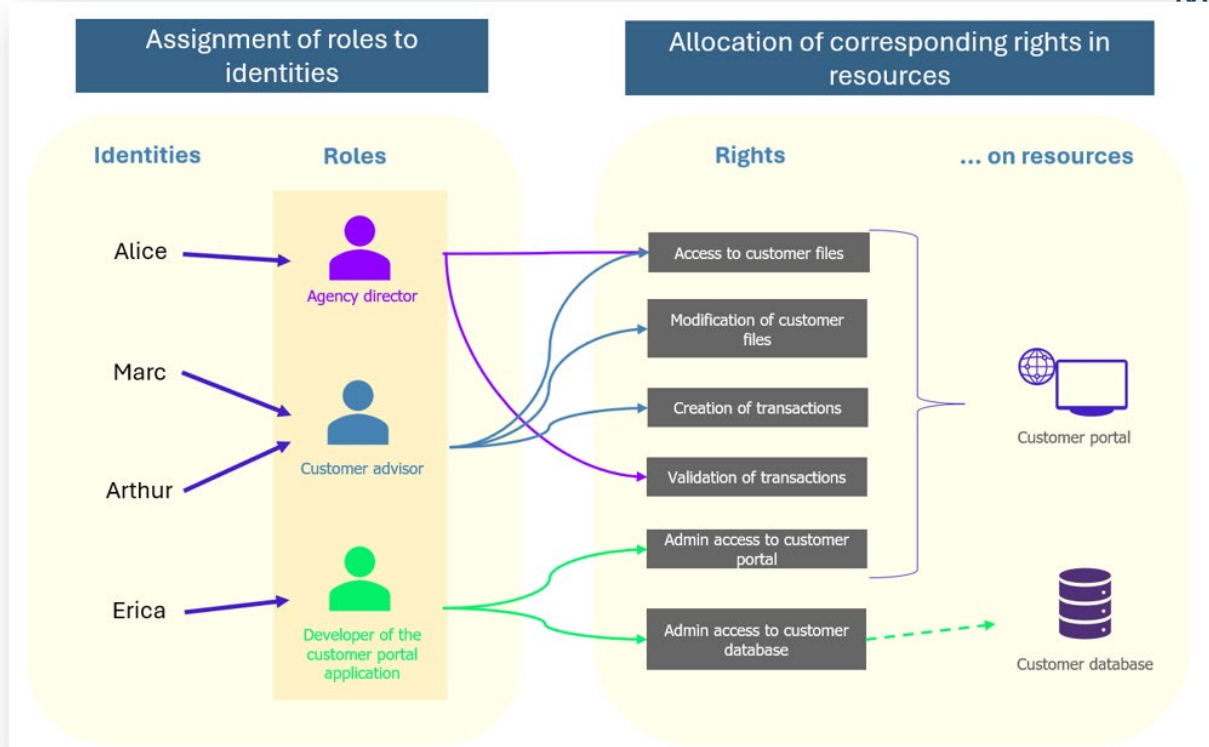
- No single person should possess two permissions that, in combination, allow them to perform a sensitive operation.
- Most common requirement in highly regulated industries:
 - Finance/Accounting
 - Healthcare
- Protection against
 - Fraud: Making it harder to collude
 - Errors: Second eye can identify mistakes
 - Conflict of Interest



Role-Based Access Control (RBAC)

- An access control model where permissions are assigned to specific **roles** rather than individuals. Users are then assigned to roles based on their job functions
- Scalable and easier to manage in large organizations
- Reduces administrative overhead
- Example
 - In a company, employees are assigned roles like **Admin**, **Editor**, and **Viewer**.
 - Each role has predefined access to systems and data.

Role-Based Access Control (RBAC)



Account Types (1/2)

User Account

- routine access level for resources
- every employee (receptionist, CEO) has a normal user account, but access level may differ

Administrator Account

- belong to system administrators
- extensive privileges to modify system configurations
- highly sensitive
- Protect through Privileged Account Management (PAM)
- More use results in more likelihood of mistakes and compromise, therefore not used for routine tasks

Account Types (2/2)

Guest Account

- Temporary access to resources
- Used, for example, to grant access of Network to a Visitor
- Should be tied to a unique individual + should expire after reasonable time period

Shared/Generic Account

- Not recommended
- One user can deny (repudiate) an action

Service Account

- Used by the system internally
- Privileged access
- Should not be used to login interactively
- password not known to individuals (rather uses in-system secrets)

NON-REPUDIATION



Definition

- Repudiation is a term that means denying that something is true



Example

- You agree to pay someone \$10,000 in exchange for a car
- You later repudiate your agreement and claim that you never agreed to purchase the car or that you agreed to pay a lower price
- Reason: handshake agreement
- Solution: Signed agreement (signature on paper) -> admissible evidence in the court of law



Digital World

- Digital Signature
- Biometric evidence



جامعة الملك عبد الله
للعلوم والتقنية
King Abdullah University of
Science and Technology